安全事件处置法律行动意见

本题需尽快向 FTC 通报。发现日 2025-03-03，最迟 2025-04-02；4800 人的特定控制例外不免除 550 人事件的通报义务。本意见及草稿均为假设演练，未发送。

适用规则和引用链

FTC 业务指南实际链接到 eCFR Part 314 及具体条款，Sources 记录原链接。以 2025-01-01 冻结 XML 为适用版，当前网页仅检索。2021 旧 XML 用于比较；2021 最终规则细化 QI、控制及小机构例外，2023 最终规则增加(j)，314.5 记载 2024-05-13 生效。2023 PDF 本地页 1,8 可核对。

公司受 FTC 规则覆盖为题设，不重新推断真实管辖。314.2(m)定义 notification event：未授权取得未加密客户信息；密钥被未授权取得使加密信息按未加密处理；未授权访问存在推定取得且无可靠反证。本案已明确下载且 550 人，达到至少 500 门槛。

小机构例外与缺口

gap	status	citation
未指定 Qualified Individual	法定义务适用	314.4(a)
无书面风险评估	特定书面义务豁免；一般风险评估仍适用	314.4(b)、(b)(1)、314.6
无 MFA	法定义务适用，注意规则允许的替代条件	314.4(c)(5)
无持续监控或渗透测试	(d)(2)特定测试豁免；(d)(1)一般测试/监测适用	314.4(d)(1)、(d)(2)、314.6
无书面事件应急计划	(h)法定书面计划豁免；自愿建议制定	314.4(h)、314.6
无年度董事会安全报告	(i)特定义务豁免；自愿治理建议	314.4(i)、314.6
云服务合同无安全义务	法定义务适用	314.4(f)(1)-(3)
仅通用入职培训，无安全持续更新	法定义务适用	314.4(e)
已发生 550 人通知事件	法定义务适用	314.2(m)、314.4(j)、314.5

事件时间与执法请求

314.4(j)(2)使非涉事员工 Alex 在 03-03 的知悉归属于机构。03-06 管理层、03-07 顾问不是新的起算点。发现日之后 30 个日历日为 04-02，仍须 as soon as possible。

314.4(j)(1)(vi)涉及执法书面决定和公开延迟：最初可请求在向 FTC 通知后最多 30 日，书面申请可再延长最多 60 日，进一步须 FTC 工作人员判断。这里仅口头请求，无适格书面材料，也不是对 FTC 报送的自动暂停。应请警方澄清/书面化，但不以此等待报送。

立即行动和内部期限

今天：合规负责人/法务核实 550 人数、数据及发现时点，组织电子通报审核；安全人员保全日志、收回泄露密钥并限制暴露，记录未完成事项。管理层确认 Qualified Individual 职责与资源。

7 天内：QI 核对一般风险评估与有效监测，优先落实 MFA、供应商安全义务与针对性培训；补证和实际完成情况写入登记。

30 天内：核验改进有效性、复查服务商与剩余风险，建议自愿形成书面响应流程并向高管报告。今天/7 天/30 天是内部建议，不是法规授权宽限；不能据此推迟 FTC 尽快报告。

边界情景

consumers_maintained	affected	exemption	FTC_notice	safeguards
4800	550	(b)(1),(d)(2),(h),(i)	是	其余义务仍适用
5000	550	不适用 fewer than 5000 例外	是	题述四项特定义务也不再豁免
4800	499	(b)(1),(d)(2),(h),(i)	本假设不达(j)至少 500 门槛	安全计划和其余义务不因此消失；人数需持续核实

待核实范围

原始机构身份、完整受影响范围、证据保全与正式电子表格细节仍须核实。州法及其他监管/客户通知义务不在所给法律材料确定范围内，需另行核查。不得将本草稿当作完成通知。